

Chapter 5

Security Mechanisms

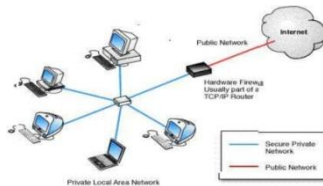
A. Firewalls

- a router or other communications device which **filters** access to a protected network.
- also a **program** that screens all **incoming traffic** and protects the network from intruders.
- It is a means of protection a **local system** or network of systems from **network-based security threats**.
 - a device that filters all traffic between a protected(inside) network and outside network.
 - runs on a **dedicated device**, because it is a **single point** through w/c traffic is **channeled** and its performance is important.

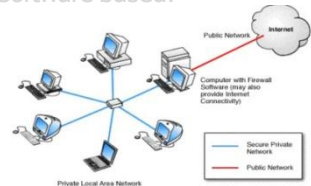
A. Firewalls

- a router or other communications device which **filters** access to a protected network.
- also **a program** that screens all **incoming traffic** and protects the network from intruders.
- It is a means of protection **a local system** or network of systems from **network-based security threats**.
 - a device that filters all traffic between a protected(inside) network and outside network.
 - runs on **a dedicated device**, because it is **a single point** through w/c traffic is **channeled** and its performance is important.
 - **purpose** of a firewall is to keep "**bad**" things outside a protected environment.
 - firewalls **implement** a security policy that is specifically **designed to address what bad things might happen**.

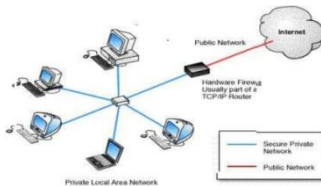
- Firewalls are often **categorized** as either:
 - Network firewalls**: **filter traffic** between two or more networks and run on network hardware.
 - Host-based firewalls** **run** on host computers and **control** network traffic **in and out** of those machines.
- The firewalls implement **hardware or software solutions** based on the control of network connections between local network and other networks.



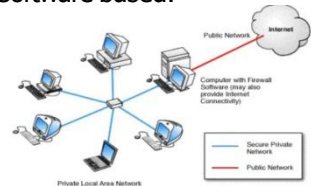
- Software based.



- Firewalls are often **categorized** as either:
 - Network firewalls**: **filter traffic** between two or more networks and run on network hardware.
 - Host-based firewalls** **run** on host computers and **control** network traffic **in and out** of those machines.
- The firewalls implement **hardware or software solutions** based on the control of network connections between local network and other networks.



- Software based.



- **Hardware firewalls**
- **Software firewalls**

■ Hardware firewalls

- can be **purchased** as a stand-alone product but are also typically found in **broadband routers**
- Most will have a minimum of **four network ports** to connect other computers.

■ Software firewalls

- are **installed** on your computer (like any software)
- allowing you some **control** over its function and protection features.
- will **protect** your computer from outside attempts to control or gain access your computer.

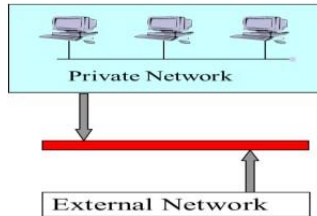
- **Windows Firewall:** is a software component of Microsoft Windows that provides firewalling and packet filtering functions.

Popular hardware & software firewalls

<i>Software Firewall</i>	<i>Hardware Firewall</i>
Windows Firewall	Cisco PIX
ZoneAlarm	Fortiguard
Comodo Firewall	Cyberoam
Norton Internet Security	Check Point
Outpost	NetScreen
BlackICE	NetD
Macfee Internet Security	WatchGuard

4

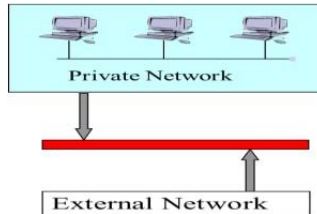
Firewall Objectives



5

Firewall Objectives

- Keep intruders, malicious code and unwanted traffic or information out
- Keep private and sensitive information in
- security wall between private (protected) network and outside world.



Firewall features

■ General Firewall Features

- Port Control
- Packet Filtering
- Network Address Translation
- Access control
- Application Monitoring

■ Additional features

- Data encryption
- reporting/logging
- Authentication
- e-mail virus protection

■ **Use one or both methods:** Packet filtering or Proxy service.

■ **It protects from:** Remote logins, IP spoofing, source addressing, SMTP session hijacking, Spam and Denial of service.....etc.

Firewall design principles

- Internet connectivity is **no longer an option** for most organizations. However, while internet access **provides** benefits to the organization,
- It enables the outside world to **reach** and interact with local network assets.
- The **firewall** is inserted between the **premise network** and **internet** to establish a controlled link and to create an outer security wall or perimeter.
- aim is to protect the premises network from internet based attacks and to provide a **single choke point security** can be imposed.

Firewall design principles

- Internet connectivity is **no longer an option** for most organizations. However, while internet access **provides** benefits to the organization,
- It enables the outside world to **reach** and interact with local network assets.
 - creates the threat to the organization
 - Soln:** possible to **equip** each workstation and server on the **premises network** with **strong security features**, such as intrusion protection, this is **not a practical** approach the alternative accepted is the **firewall**.
- The **firewall** is inserted between the **premise network** and **internet** to establish a controlled link and to create an outer security wall or perimeter.
- aim is to protect the premises network from internet based attacks and to provide a **single choke point security** can be imposed.

Firewall characteristics

- All traffic from inside to outside, and vice versa, must pass through the firewall.
- Various configurations are possible, only authorized traffic is defined by the **local security policy**, will be allowed to pass.
- The firewall itself is **immune to penetration**. This implies that use of a trusted system with a secure operating system.
- **Four techniques that firewall use to control access and enforce the sites security policy** is as follows:
 - **Service control** : determines what types of services can be accessed.
 - **Direction control**: determines in which direction particular **service request** may be initiated
 - **User control**: determines access to a service **according** to a user.
 - **Behavior control**: controls how particular services are used.

Capabilities of firewall

- **A firewall:** defines a **single choke point** that keeps unauthorized users out of the protected network.
prohibits potentially **vulnerable services** from entering or leaving the network.
 - provides a location for monitoring security related events and alarms can be implemented on the firewall system.
- **Limitations of firewall:**
 - cannot protect against **attacks** that by pass the firewall.
 - does not protect against **internal threats**, such as a disgruntled employee or an employee who unwittingly cooperates with an external attacker.
 - cannot protect against the **transfer** of virus-infected programs or files.

Types of firewalls

- **common types** of firewalls:
 1. Packet Filtering Firewalls (**Layer 3**)
 2. Application-level gateways/ Proxy Server Firewalls (**Layer 7**)
 3. Circuit-level gateways (**Layer 5**)
 4. **Stateful Inspection Firewall (Layers 3 & 4)**

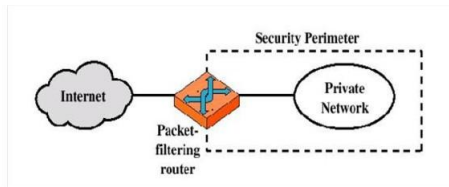
Let us see the different types of firewall

<https://www.paloaltonetworks.com/cyberpedia/types-of-firewalls>

A. Packet Filtering Gateway

- a **Pkt filtering gateway**: controls access to Pkt on the basis of **Pkt address** source or destination /transport protocol(HTTP web traffic).
- a Pkt filtering router applies a set of rules to each incoming IP Pkt and then forwards or discards the Pkt.
 - router is typically configured to filter Pkts going in both directions
- Filtering rules based on the information contained in a network Pkt:
 - **Source IP address**: IP address of the system that originated the IP packet.
 - **Destination IP address**: The IP address of the system the IP packet is trying to reach.
 - **Source and destination port address**: The transport level(TCP or UDP) port number- applications such as SNMP or TELNET.
 - **IP protocol field** – defines the transport protocol.
 - **Interface**: for a router with three or more ports, which interface of the router the packet come from or which interface of the router.

- The packet filter is typically **set up** as a list of rules based on matches to fields in the IP or TCP header.



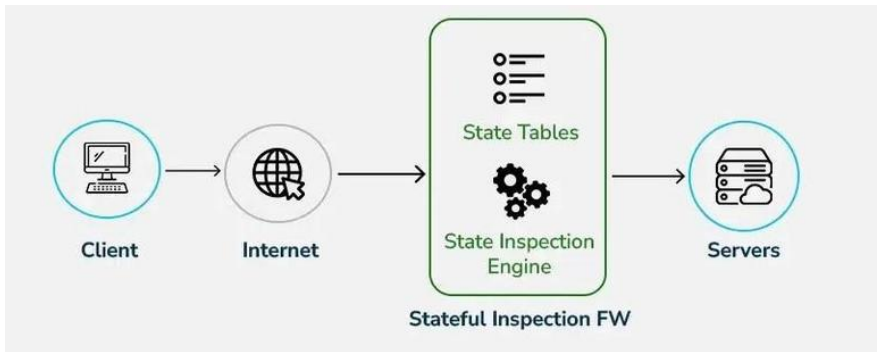
IP source	IP dest	Port source	Port dest	Action
any	192.54.113.10	any	25	allow
93.54.84.35	any	any	23	allow
any	any	any	23	deny

- If there is a **match** to one of the rules, that rule is **invoked** to determine whether to forward or discard the packet.
- If there is **no match** to any rule, then a default action is taken. Two default policies are possible:
Default = discard/forward
- Packet filtering is generally accomplished using **Access Control Lists (ACL)** on routers
 - Filtering firewalls inspect packets at the **network layer**, or **Layer 3**.

- **Some of the attacks that can be made on packet filtering routers and the appropriate counter measures are the following:**
 - **IP address spoofing:** – the intruders transmit packets from the outside with a **source IP address** field containing an address of an internal host.
 - **Source routing attacks:** – the source station specifies the route that a packet should take as it crosses the internet; i.e., it will bypass the firewall.
 - **Tiny fragment attacks:** – the intruder create extremely small fragments and force the TCP header information into a separate packet fragment.

B. Stateful Inspection Firewall

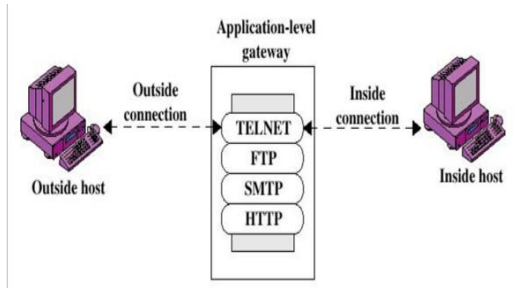
- Tracks active connections and makes decisions based on traffic context.
- More secure than packet filtering
- Remembers past traffic (state table)
- Blocks suspicious or unexpected packets



C. Application level gateway

- An application level gateway, also called a **proxy server**, acts as a relay of application level traffic.
 - can **filter** packet at the application layer of OSI model
 - incoming and outgoing packet can not access service for which there is no proxy. **Example**
- an application level gateway that is configured to be a **web proxy** will not allow any FTP, telnet or other traffic

- A prime **disadvantage** is the **additional processing overhead** on each connection.

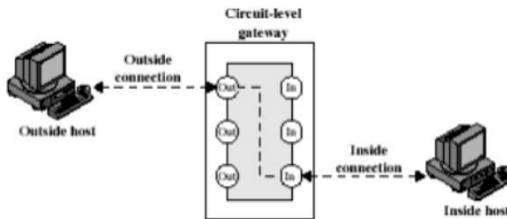


7

D. Circuit level gateway

- **Circuit level gateway:** can be a stand-alone system or it can be a specified function performed by an application level gateway.
 - Filter a packets at the **Transport layer** of OSI model.
 - Traffic is filtered based on the specified **session Rules**
 - the gateway sets up **two TCP connections**
 - one between itself and a TCP user on an inner host and
 - one between itself and a TCP user on an outer host.
- Once the connections are established, both connections are linked by a gateway.

- The gateway can be configured to support **application level** or proxy service on in bound connections and circuit level functions for outbound connections.



(c) Circuit-level gateway

E. next generation firewall Requirements

- identify application not ports identify users not IP
- addressee
- inspect content in real time(deep pkt analysis) simplify policy
- management
- Deliver multi gigabit throughput

Advanced firewall combining multiple security features:

- Includes intrusion prevention, malware detection
- Can inspect encrypted traffic
- Provides app-level filtering

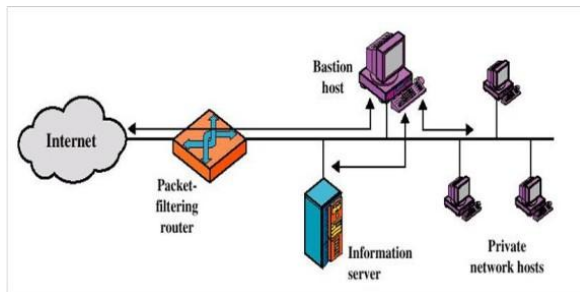
Firewall configurations

- There are 3 common firewall configurations.

1. Screened host firewall, single-homed Bastion configuration

- the firewall consists of two systems: a packet filtering router and a bastion host.
- Typically, the router is configured so that
 - For traffic from the internet, only IP packets destined for the Bastion host are allowed in.
 - For traffic from the internal network, only IP packets from the Bastion host are allowed out.

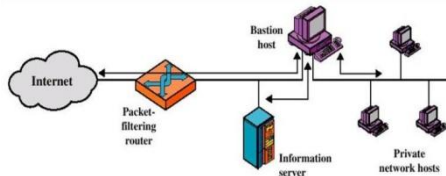
- The Bastion host performs authentication and proxy functions.
- This configuration has greater security than simply a packet filtering router or an application level gateway alone, for two reasons:
 - ① This configuration implements both packet level and application level filtering, allowing for considerable flexibility in defining security policy.
 - ② An intruder must generally penetrate two separate systems before the security of the internal network is compromised.



9

2.Screened host firewall, dual homed Bastion configuration

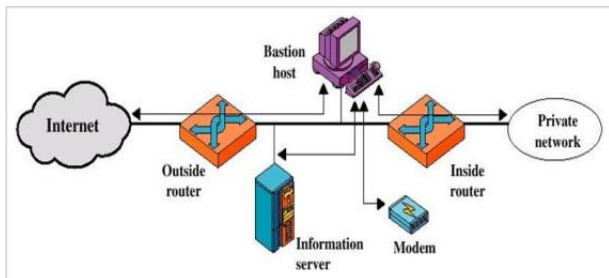
- previous configuration, if the packet filtering router is compromised, traffic could flow directly through the router between the internet and the other hosts on the private network. This configuration physically prevents such a security break.
- Traffic between the Internet and other hosts on the private network has to flow through the bastion host
- Uses** two NICs for greater security.



10

3.Screened subnet firewall configuration

- In this configuration, two packet filtering routers are used,
 - One between the **Bastion host** and **internet** and
 - One between the Bastion host and the internal network.
- This configuration **creates** an isolated sub network, which may **consist** of simply the Bastion host but may also include one or more information servers
- This configuration offers several advantages:
 - There are now three levels of defense to prevent intruders.
 - The outside router advertises only the existence of the screened subnet to the internet; therefore the internal network is invisible to the internet.
 - Similarly, the inside router advertises only the existence of the screened subnet to the internal network; therefore the systems on the internal network cannot construct direct routes to the internet.



11

Network Address Translation(NAT)

- NAT is usually implemented in a firewall separately from the policy or rule set.
- It useful to remember that just because a NAT has been defined to translate addresses between one host and another

Intrusion Detection and Prevention Systems

- An IDS is a device that **monitors** activity to **identify** malicious or suspicious events.
- An IDS **receives** raw inputs from sensors, saves them, analyzes them, and takes some controlling action. It is based on the Common **Intrusion Detection Framework (CIDF)**.
- **IDS** is software that **automates** the intrusion detection process.

Intrusion prevention system (IPS)

- An IPS is software that has all the **capabilities** of an IDS and can also attempt to **stop** possible incidents.
 - They use several response techniques:
 - The IPS stops the attack itself. **Examples** how this could be done include the IPS **terminating** the network **connection** being used for the attack and the IPS **blocking** access to the target from the offending **user account**, **IP address** other attacker attribute
 - The IPS **changes** the security environment
 - The IPS could change the **configuration** of other security controls to disrupt an attack
- Example:** Common examples are the IPS re configuring a network firewall to block access from the attacker.

- There are **two** types of IDS
 - **Signature-based IDS Signature**
 - look for patterns
 - perform simple pattern-matching and report situations that match a pattern (signature) corresponding to an attack type.
 - Signature-based IDSs are limited to **known** patterns.
 - Signature-based intrusion detection works well on certain types of denial-of-service attacks.
 - **Heuristic(Anomaly) IDS**
 - ones learn **characteristics** of unacceptable behavior over time
 - build a model of acceptable behavior and flag exceptions to that model.
 - Heuristic intrusion detection infers attacks by tracking suspicious activity.

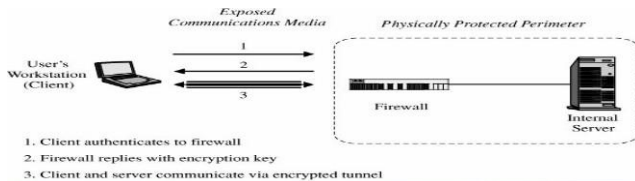
IDSs perform a variety of functions :

- Monitoring users and system activity
- Auditing system configuration for vulnerabilities and misconfigurations
- Assessing the integrity of critical system and data files
- Recognizing known attack patterns in system activity
- Identifying abnormal activity through statistical analysis
- Managing audit trails and highlighting user violation of policy or normal activity
- Correcting system configuration errors

- Intrusion detection devices can be network based or host based.
- **A network-based IDS:** is a stand-alone device attached to the network to monitor traffic throughout that network;
- **A host-based IDS :** runs on a single workstation or client or host, to protect that one host.
- **Goals for Intrusion Detection Systems**
 - An IDS could use some or all of the following design approaches:
 - Filter on packet headers
 - Filter on packet content
 - Maintain connection state
 - Use complex, multipacket signatures

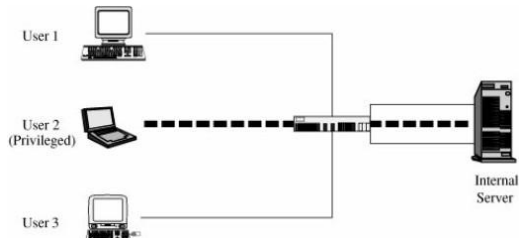
Virtual Private Networks(VPN)

- is a type of private network that **uses** public telecommunication, instead of leased line to connection.
- Employees can access the network (Intranet) from remote locations.
- The larger network is **restricted** only to those given special access by the VPN. Users feels the network is private, even though it is not.
- With the VPN, the communication passes through an encrypted **tunnel** or tunnel.



1

- The **user's client** and the firewall negotiate a **session** encryption key, and the **firewall** and the **client** subsequently use that key to encrypt all traffic between the two.
- Virtual private networks are **created** when the **firewall** interacts with an authentication service inside the perimeter.



- VPNs have **two important** components:
 - Tunneling to create the virtual network
 - Encryption to **enable** privacy and security
- **Virtual Network**
 - To build a virtual network, a **tunnel** is created between the two endpoints.
 - In a site-to-site VPN, hosts send and receive normal **TCP/IP traffic** through a VPN gateway.
 - A tunnel by itself may **not** guarantee security.
 - The tunnel simply creates an extension of the local network across the WAN or public network.
 - Tunnels can carry either encrypted or unencrypted content.

■ VPN Tunnel Protocols

- VPN tunnels are created using a number of different encapsulation protocols.
- These protocols include:
 - Generic routing encapsulation (GRE)
 - IP Security (IPSec)
 - Layer 2 Forwarding (L2F) Protocol
 - Point-to-Point Tunneling Protocol (PPTP)
 - Layer 2 Tunneling Protocol (L2TP)
- VPN technologies use **encryption algorithms** that prevent data from being read if it is intercepted.
Data Encryption Standard (DES), Triple DES (3DES), Advanced Encryption Standard (AES), and Rivest, Shamir, and Adleman (RSA).

proxy server

- A **proxy server** acts as an intermediary gateway between a user's device and the internet, processing requests on behalf of the client to provide security, administrative control, or caching services.
- In the context of your study materials, a **Web Application Firewall (WAF)** often operates as a **reverse proxy**, inspecting incoming HTTP/HTTPS traffic against security policies before it reaches the web server.

How a Proxy Works

- **Request:** Instead of connecting directly to a website, your device sends the request to the proxy server.
- **Processing:** The proxy evaluates the request. It can filter content, mask your IP address, or check for malicious patterns.
- **Forwarding:** If the request is safe, the proxy forwards it to the destination server.
- **Response:** The destination server sends the data back to the proxy, which then passes it to you.

Type	Purpose	Key Function
Forward Proxy	Protects Clients	Sits in front of users to hide their internal IP addresses and bypass content filters.
Reverse Proxy	Protects Servers	Sits in front of web servers (like a WAF) to handle load balancing and defend against attacks like SQL injection.
Caching Proxy	Performance	Saves copies of frequently visited websites to speed up future requests and save bandwidth.
Anonymous Proxy	Privacy	Strips the identifying information of the client so the destination server cannot track the user.

Security Benefits

- **Anonymity:** By masking the client's IP, it prevents attackers from directly targeting the user's machine.
- **Filtering:** Organizations use proxies to block access to malicious or unproductive websites.
- **Traffic Inspection:** Proxies like WAFs monitor "Layer 7" (Application Layer) traffic to block threats that traditional firewalls might miss, such as cross-site scripting (XSS).
- **Mitigation:** They can help absorb **DDoS attacks** by filtering out overwhelming volumes of malicious requests before they hit the main infrastructure.